
Algorithm 1 Bayesian Multi-Agent Vulnerability Detection

Input:
 D : pull request diff
 R : repository context
 $\mathcal{M}$: agent models and rule sets
 π : prior probability of vulnerability
 Λ : fitted likelihood-ratio table
 τ_V, τ_S : vulnerable / safe thresholds
 τ_D : disagreement threshold

Output:
 Y : final verdict
 $P(V | E)$: posterior vulnerability probability
 DI : inter-agent disagreement index
 F, Z : patch and verification status

```

1:  $C \leftarrow \text{EXTRACTCHANGEDCODE}(D)$ 
2:  $C \leftarrow \text{IDENTIFYMODIFIEDFUNCTIONS}(C)$ 
3:  $X \leftarrow \text{BUILDANALYSISCONTEXT}(C, R)$ 

  // Heterogeneous evidence generation (agents run blind)
4:  $e_S \leftarrow \text{STATICAGENT}(X, \mathcal{M}_S)$ 
5:  $e_M \leftarrow \text{SEMANTICAGENT}(X, \mathcal{M}_M)$ 
6:  $e_C \leftarrow \text{CONTEXTAGENT}(X, \mathcal{M}_C)$ 
7:  $e_R \leftarrow \text{RUNTIMESFI}(X, \mathcal{M}_R)$ 
8:  $E \leftarrow \{e_S, e_M, e_C, e_R\}$ 

  // Evidence cell and likelihood ratio, one per agent
9: for all  $a \in \{S, M, C, R\}$  do
10:    $z_a \leftarrow \text{CELL}(e_a)$  ▷ Eq. (6)
11:   if  $e_a$  could not run then
12:      $L_a \leftarrow 1$  ▷ no evidence  $\Rightarrow$  no update
13:   else
14:      $L_a \leftarrow \text{clamp}(\Lambda_a[z_a])$  ▷ Eq. (7)
15:   end if
16: end for

  // Bayesian evidence fusion
17:  $O \leftarrow \pi / (1 - \pi)$ 
18:  $O_{\text{post}} \leftarrow O \times L_S \times L_M \times L_C \times L_R$ 
19:  $P(V | E) \leftarrow O_{\text{post}} / (1 + O_{\text{post}})$ 

  // Inter-agent disagreement
20: for all  $a \in \{S, M, C, R\}$  do
21:    $p_a \leftarrow \pi L_a / (\pi L_a + 1 - \pi)$  ▷ Eq. (8)
22: end for
23:  $\bar{p} \leftarrow \frac{1}{4} \sum_a p_a$ 
24:  $DI \leftarrow \sqrt{\frac{1}{4} \sum_a (p_a - \bar{p})^2}$ 

  // Final decision
25: if  $P(V | E) \geq \tau_V$  then
26:    $Y \leftarrow \text{VULNERABLE}$ 
27: else if  $P(V | E) \leq \tau_S$  then
28:    $Y \leftarrow \text{SAFE}$ 
29: else
30:    $Y \leftarrow \text{UNCERTAIN}$ 
31: end if
32: if  $DI \geq \tau_D$  then
33:    $Y \leftarrow \text{ATTACHUNCERTAINTYFLAG}(Y)$ 
34: end if

  // Remediation
35: if  $Y = \text{VULNERABLE}$  then
36:    $F \leftarrow \text{PATCHAGENT}(C, E)$ 
37:    $Z \leftarrow \text{VERIFIER}(F, C)$ 
38: else
39:    $F \leftarrow \emptyset$ ;  $Z \leftarrow \text{NOTREQUIRED}$ 
40: end if

41: return  $Y, P(V | E), DI, F, Z$ 

```

PER-AGENT EVIDENCE EQUATIONS

Each agent replies in one of three ways: *found something* with a raw score $\varrho \in [0, 1]$, *ran and found nothing*, or *could not run*. Each obtains its ϱ as follows.

A. Static agent. Taint starts at every parameter and follows the def-use graph G_c , which is the graph with all edges that sanitise class c removed. A dangerous call is reported only if a real path π from a parameter to it exists in G_c :

$$\varrho_S = \text{clamp}_{[0,1]}(0.45 + \delta(d) - 0.25\varsigma - 0.0125\ell(\pi) + 0.15\nu - 0.20\tau) \quad (1)$$

$\ell(\pi) = \min(\max(0, |\pi| - 2), 4)$; δ is 0.20 for a critical call and 0.10 for a high one; ς, ν, τ flag a partial sanitiser, a network-facing unit and a test file.

B. Semantic agent. The model is queried $n = 3$ times with different seeds, and the score is its agreement with itself:

$$\varrho_M = \frac{|\{i : \text{sample } i \text{ reports this weakness}\}|}{n} \quad (2)$$

A finding is kept only if its class is in scope, its file is the unit's, the line it quotes appears verbatim, and its line numbers lie inside the unit:

$$\Gamma(\phi) = [c(\phi) \in \text{CWE}_{\text{sc}}] \wedge [\text{file}(\phi) = f] \wedge [\text{sink}(\phi) \sqsubseteq s^+] \wedge [\text{lines}(\phi) \subseteq [1, L_u]] \quad (3)$$

C. Context agent. A control γ is *established* if the same function carried it in an earlier merge, or if two or more distinct retrieved functions use it. One established but missing from the new code gives

$$\varrho_C = b \cdot \min(1, \bar{s}/0.85) \quad (4)$$

with $b = 0.85$ when the same function carried γ or three or more others do, else $b = 0.65$, and $\bar{s}$ the mean similarity of the supporting excerpts.

D. Runtime agent. The function runs once in a WebAssembly sandbox with no network and no environment, each parameter bound to a unique marker t_i , so taint is substring containment. An execution either happened or it did not:

$$\text{tainted}(v) \iff \exists i : t_i \sqsubseteq v, \quad \varrho_R = 0.85 \quad (5)$$

If the value reached the sink only after a check the sandbox could not evaluate, the agent replies *could not run*.

E. Cells and fusion. Scores map to four cells, each cell to one fitted ratio:

$$z_a = \begin{cases} \text{STRONG} (\varrho_a \geq 0.8), & \text{MEDIUM} (0.5 \leq \varrho_a < 0.8) \\ \text{WEAK} (\varrho_a < 0.5), & \text{NONE} (\text{ran, found nothing}) \end{cases} \quad (6)$$

$$\Lambda_a(z) = \frac{P(z_a = z | V)}{P(z_a = z | \neg V)} \approx \frac{(n_1(z) + \alpha)/(N_1 + 4\alpha)}{(n_0(z) + \alpha)/(N_0 + 4\alpha)} \quad (7)$$

An agent that could not run contributes exactly 1, so it cannot move the posterior. The probability behind the disagreement index is that agent's factor alone:

$$p_a = \pi L_a / (\pi L_a + 1 - \pi) \quad (8)$$